Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

Payment Card Industry
Data Security Standard

Attestation of Compliance for Report on Compliance – Service Providers

Version 4.0.1

Publication Date: August 2024

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

PCI DSS v4.0.1 Attestation of Compliance for Report on Compliance – Service Providers

Entity Name: GitHub, Inc. (dba GitHub)

Date of Report as noted in the Report on Compliance: 1/6/2026

Date Assessment Ended: 12/29/2025

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

Section 1: Assessment Information

Instructions for Submission

This Attestation of Compliance (AOC) must be completed as a declaration of the results of the service provider's assessment against the *Payment Card Industry Data Security Standard (PCI DSS) Requirements and Testing Procedures (*"Assessment"). Complete all sections. The service provider is responsible for ensuring that each section is completed by the relevant parties, as applicable. Contact the entity(ies) to which this AOC will be submitted for reporting and submission procedures.

This AOC reflects the results documented in an associated Report on Compliance (ROC). Associated ROC sections are noted in each AOC Part/Section below.

Capitalized terms used but not otherwise defined in this document have the meanings set forth in the PCI DSS Report on Compliance Template.

Part 1. Contact Information	
Part 1a. Assessed Entity (ROC Section 1.1)	
Company name:	GitHub, Inc.
DBA (doing business as):	GitHub
Company mailing address:	88 Colin P Kelly Jr Street San Francisco, CA 94107
Company main website:	https://github.com/
Company contact name:	Alexis Wales
Company contact title:	Chief Information Security Officer
Contact phone number:	+1 415-735-4488
Contact e-mail address:	alexiswales@github.com
Part 1b. Assessor (ROC Section 1.1)	
Provide the following information for all assessors involved in the Assessment. If there was no assessor for a given assessor type, enter Not Applicable.	
PCI SSC Internal Security Assessor(s)	
ISA name(s):	Not Applicable
Qualified Security Assessor	
Company name:	Coalfire Systems, Inc.
Company mailing address:	330 N Wabash, Suite 1430 Chicago, IL 60611
Company website:	https://www.coalfire.com
Lead Assessor name:	Blake Yanez
Assessor phone number:	+1 877-244-8077
Assessor e-mail address:	CoalfireSubmission@coalfire.com

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Assessor certificate number:	QSA #206-170

Part 2. Executive Summary

Part 2a. Scope Verification

Services that were INCLUDED in the scope of the Assessment (select all that apply):

Name of service(s) assessed:	GitHub Enterprise Cloud, Proxima (GitHub Enterprise Cloud with Data Residency), GitHub Copilot, GitHub Actions

Type of service(s) assessed:

Hosting Provider:	**Managed Services:**	**Payment Processing:**
☒ Applications / software ☐ Hardware ☐ Infrastructure / Network ☐ Physical space (co-location) ☒ Storage ☐ Web-hosting services ☐ Security services ☐ 3-D Secure Hosting Provider ☒ Multi-Tenant Service Provider ☐ Other Hosting (specify): Not Applicable	☐ Systems security services ☐ IT support ☐ Physical security ☐ Terminal Management System ☐ Other services (specify): Not Applicable	☐ POI / card present ☐ Internet / e-commerce ☐ MOTO / Call Center ☐ ATM ☐ Other processing (specify): Not Applicable
☐ Account Management	☐ Fraud and Chargeback	☐ Payment Gateway/Switch
☐ Back-Office Services	☐ Issuer Processing	☐ Prepaid Services
☐ Billing Management	☐ Loyalty Programs	☐ Records Management
☐ Clearing and Settlement	☐ Merchant Services	☐ Tax/Government Payments
☐ Network Provider		
☐ Others (specify): Not Applicable		

Note: *These categories are provided for assistance only and are not intended to limit or predetermine an entity's service description. If these categories do not apply to the assessed service, complete "Others." If it is not clear whether a category could apply to the assessed service, consult with the entity(ies) to which this AOC will be submitted.*

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Part 2. Executive Summary *(continued)*

Part 2a. Scope Verification *(continued)*

Services that are provided by the service provider but were NOT INCLUDED in the scope of the Assessment (select all that apply):

Name of service(s) not assessed:	Not Applicable

Type of service(s) not assessed:

Hosting Provider:	**Managed Services:**	**Payment Processing:**
☐ Applications / software ☐ Hardware ☐ Infrastructure / Network ☐ Physical space (co-location) ☐ Storage ☐ Web-hosting services ☐ Security services ☐ 3-D Secure Hosting Provider ☐ Multi-Tenant Service Provider ☐ Other Hosting (specify): Not Applicable	☐ Systems security services ☐ IT support ☐ Physical security ☐ Terminal Management System ☐ Other services (specify): Not Applicable	☐ POI / card present ☐ Internet / e-commerce ☐ MOTO / Call Center ☐ ATM ☐ Other processing (specify): Not Applicable
☐ Account Management	☐ Fraud and Chargeback	☐ Payment Gateway/Switch
☐ Back-Office Services	☐ Issuer Processing	☐ Prepaid Services
☐ Billing Management	☐ Loyalty Programs	☐ Records Management
☐ Clearing and Settlement	☐ Merchant Services	☐ Tax/Government Payments
☐ Network Provider		
☐ Others (specify): Not Applicable		

Provide a brief explanation why any checked services were not included in the Assessment:	Not Applicable

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

Part 2b. Description of Role with Payment Cards (ROC Sections 2.1 and 3.1)	
Describe how the business stores, processes, and/or transmits account data.	GitHub does not directly store, process, or transmit cardholder data (CHD) for its own business purposes. GitHub customers are responsible for all storage and protection of cardholder data.
Describe how the business is otherwise involved in or has the ability to impact the security of its customers' account data.	GitHub does not directly store, process, or transmit account data for its own business purposes. GitHub customers are responsible for all storage and protection of cardholder data. <u>GitHub Enterprise Cloud</u> GitHub Enterprise Cloud offers the following features: • Organizations – An organization is a collection of user accounts that owns repositories. Organizations have one or more owners, who have administrative privileges for the organization. When a user creates an organization, it does not have any repositories associated with it. At any time, members of the organization with the Owner role can add new repositories or transfer existing repositories. • Code Hosting – GitHub is one of the largest code hosts in the world, with millions of projects. Private, public, or open source repositories are equipped with tools to host, version, and release code. Unlimited private repositories allow keeping the code in one place, even when using Subversion (SVN) or working with large files using Git Large File Storage (LFS). Changes can be made to code in precise commits allowing for quick searches on commit messages in the revision history to find a change. In addition, blame view enables users to trace changes and discover how the file, and code base, has evolved. With sharing, changes can be packaged from a recently closed milestone or finished project into a new release. Users can draft and publish release notes, publish pre-release versions, attach files, and link directly to the latest download. • Code Management – Code review is a critical path to better code, and it's fundamental to how GitHub works. Built-in review tools make code review an essential part of team development workflows. A pull request (PR) is a living conversation where ideas can be shared, tasks assigned, details discussed, and reviews conducted. Reviews happen faster when GitHub shows a user exactly what has changed. Diffs compare versions of source code side by side, highlighting the parts that are new, edited, or deleted. PRs also enable clear feedback, review requests, and comments in context with comment threads within the code. Comments may be bundled into one review or in reply to someone else's comments inline as a conversation. GitHub allows customers to protect important branches by setting branch protection rules, which define whether collaborators can delete or force push to the branch and set requirements for any pushes to the branch, such as passing status checks or a linear commit history. Protected branches allow for better quality code management. Repositories can be configured to require status checks, such as continuous integration tests, reducing both human error and administrative overhead. • Project Management – Project boards allow users to reference every issue and PR in a card, providing a drag-and-droppable snapshot of the work that teams do in a repository. This feature can also function as an agile idea board to capture early ideas that come up as part of a standup or team sync, without polluting the issues. Issues enable team task tracking, with resources identified and assigned tasks within a team. Issues may be used to track a bug, discuss an idea with an @mention, or start distributing work. Issue and PR assignments to one or more teammates make it clear who is doing what work and what feedback and approvals have been requested.

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

Milestones can be added to issues or PRs to organize and track progress on groups of issues or PRs in a repository.

- Teams (User Management) – NOTE: This section refers to Teams, not the plan called "GitHub Team." Building software is as much about managing teams and communities as it is about code. Users set roles and expectations without starting from scratch. Customized common codes of conduct can be created for any project, with pre-written licenses available right from the repository. Teams enable the ability to organize people, provide level-up access with administrative roles, and tune permissions for nested teams. Discussion threads keep conversations on topic using moderation tools, like issue and pull-request locking, to help teams stay focused on code. For maintaining open-source projects, user blocking reduces noise and keeps conversations productive.
- Documentation – GitHub allows for documentation to be created and maintained in any repository, and wikis are available to create documentation with version control. Each wiki is its own repository, so every change is versioned and comparable. With a text editor, users can add docs in the text formatting language of choice, such as Textile or GitHub Flavored Markdown.
- GitHub Enterprise Cloud with Data Residency (Proxima) – Proxima offers the same infrastructure and features as GitHub Enterprise Cloud, but it includes an option to store customer data in a geographic location outside of the United States. This functionality allows for easier compliance with standards that pertain to non-US locations. Proxima uses a regional collection of resources within Azure, known as “stamps”, that are open for customer usage. Terraform ensures that all stamps contain the same resources and are constructed in the same manner, where the only difference is the location in which the stamps reside.

The following two services are also included in GitHub Enterprise Cloud and are covered within the scope of this assessment:

<u>GitHub Copilot</u>

GitHub Copilot is an Artificial Intelligence (AI)-powered coding assistant that helps developers write code faster. GitHub Copilot is available through:

- GitHub Copilot Business for GitHub organization or enterprise accounts which gives control over Copilot policies, including which members can use Copilot.
- GitHub Copilot Enterprise for enterprise accounts on GitHub Enterprise Cloud, which includes all of Copilot Business features along with additional AI features on GitHub. With this subscription plan you can choose to assign either Copilot Enterprise or Copilot Business to each individual organization in the enterprise.

GitHub Copilot feature includes, but are not limited to:

- Code Completion – Autocomplete-style suggestions from Copilot in supported IDEs (Visual Studio Code, Visual Studio, JetBrains IDEs, Azure Data Studio, and Vim/Neovim).
- Copilot Chat – A chat interface that lets you ask coding-related questions. GitHub Copilot Chat is available on the GitHub website, in GitHub Mobile, and in supported IDEs (Visual Studio Code, Visual Studio, and JetBrains IDEs). Users can also use skills with Copilot Chat.
- Copilot in the CLI – A chat-like interface in the terminal, where you can ask questions about the command line. You can ask Copilot to provide command suggestions or explanations of commands.
- Copilot pull request summaries (Copilot Enterprise only) – AI-generated summaries of the changes that were made in a pull request, which files they

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

	impact, and what a reviewer should focus on when they conduct their review. • Copilot text completion (beta)(Copilot Enterprise only) – AI-generated text completion to help you write pull request descriptions quickly and accurately. • Copilot knowledge bases (Copilot Enterprise only) – Create and manage collections of documentation to use as context for chatting with Copilot. When you ask a question in Copilot Chat on GitHub.com or in VS Code, you can specify a knowledge base as the context for your question. GitHub Copilot Administrator features include, but are not limited to, policy management, access management, usage data review, audit log review, and file exclusion. <u>GitHub Actions</u> GitHub Actions automates Continuous Integration/ Continuous Delivery (CI/CD) software workflows by enabling the build, test, and deployment of code directly from GitHub, with code reviews, branch management, and issue triaging customized to work the way developers need. GitHub Actions initiates workflows for events like push, issue creation, or a new release, and actions can be combined and configured for the services used, built, and maintained by the community. GitHub Actions supports additional options to do things like build containers, deploy web services, or automate notifications to users of open source projects using GitHub developers' existing GITHUB_TOKEN in collaboration with other Enterprise Cloud features.
Describe system components that could impact the security of account data.	GitHub is a web-based software development platform built on the Git version control software. Traffic travels to and from the GitHub CDE by utilizing router/firewall combination devices (border routers) that manage and filter inbound and outbound traffic. The CDE itself resides in Azure VNETs (Virtual Networks) and AWS VPCs (Virtual Private Cloud environments). Individuals use personal accounts linked with Okta MFA and GitHub's in-house access control application, Entitlements, for authentication and authorization purposes. Entitlements acts as a series of configuration files that assign role-based access restrictions for all user accounts created via Workday and LDAP. Splunk functions as the main logging/monitoring tool across the environment, and alerts are presented to the relevant teams via Slack and Azure Event Hub. Threat detection/response matters are managed through frequent internal scans performed via Tenable, while Qualys handles all external vulnerability scans.

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Part 2. Executive Summary *(continued)*

Part 2c. Description of Payment Card Environment

Provide a high-level description of the environment covered by this Assessment. *For example:* • *Connections into and out of the cardholder data environment (CDE).* • *Critical system components within the CDE, such as POI devices, databases, web servers, etc., and any other necessary payment components, as applicable.* • *System components that could impact the security of account data.*	GitHub, Inc. ("GitHub") is a Level 1 Service Provider headquartered in San Francisco, California, with additional offices in Bellevue, WA and Oxford, UK. GitHub is a web-based software development platform built on the Git version control software. Git allows multiple users to interact with and change files on a real-time basis, providing functionalities for version history and record-keeping. Primarily used for software code, GitHub offers the distributed version control and source code management functionality of Git with additional features and enhancements. Specifically, it provides access control and several collaboration features including bug tracking, feature requests, task management, GitHub Teams, pull requests, discussions, issues, pages, projects, docs, and wikis. GitHub Enterprise Cloud with Data Residency is an optional version of GitHub Enterprise Cloud that offers features which provide customers control over the location in which their data is stored. Customers can optionally add other services; the scope of this report will include GitHub Enterprise Cloud, GitHub Enterprise Cloud with Data Residency (also known as Proxima), Copilot Business, Copilot Enterprise, and Actions. GitHub production environment is deployed inside dedicated public cloud accounts in Amazon Web Services (AWS) (Level 1 Service Provider with a compliant PCI DSS AOC version 4.0.1, dated 6/13/2025), and Microsoft Azure (Level 1 Service Provider with a compliant PCI DSS AOC version 4.0.1, dated 3/28/2025), and hosted inside various colocation data centers (data centers) for CoreSite LP (Level 1 Service Provider with a compliant PCI DSS AOC version 4.0.1, dated 6/30/2025), QTS Realty Trust, LLC (Level 1 Service Provider with a compliant PCI DSS AOC version 4.0.1, dated 6/27/2025), Equinix, Inc. (Level 1 Service Provider with a compliant PCI DSS AOC version 4.0.1, dated 11/17/2025), and Sabey Data Center Properties, LLC. (Level 1 Service Provider with a compliant PCI DSS AOC version 4.0.1, dated 11/6/2025).

Indicate whether the environment includes segmentation to reduce the scope of the Assessment. (Refer to the "Segmentation" section of PCI DSS for guidance on segmentation)	☐ Yes ☒ No

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Part 2d. In-Scope Locations/Facilities (ROC Section 4.6)

List all types of physical locations/facilities (for example, corporate offices, data centers, call centers and mail rooms) in scope for this Assessment.

Facility Type	Total Number of Locations (How many locations of this type are in scope)	Location(s) of Facility (city, country)
Microsoft Azure regions	17	Singapore: azure-southeastasia Tokyo, Japan: azure-japaneast Pune, India: azure-centralindia Dubai, UAE: azure-uaenorth Johannesburg, South Africa: azure-southafricanorth Seoul, Korea: azure-koreacentral Virginia, USA: azure-eastus Sao Paulo State, Brazil: azure-brazilsouth <u>9 edge locations in the regions above:</u> edge-cus-01 edge-ne-01 edge-wus-01 edge-frc-01 edge-uks-01 edge-jpw-01 edge-sdc-01 dge-szn-01 edge-ae-01
AWS regions	2	US East 1 US West 2
Datacenter (CoreSite)	2	USA: Ashburn: VA1 USA: Ashburn: VA3
Datacenter (Equinix)	3	USA, Washington, DC: DC2, USA, Seattle: SE3, Germany, Frankfurt: FR5
Datacenter (QTS)	1	USA: Ashburn: ASH1
Datacenter (Sabey)	1	USA, Ashburn: AC4

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

Part 2. Executive Summary *(continued)*

Part 2e. PCI SSC Validated Products and Solutions (ROC Section 3.3)

Does the entity use any item identified on any PCI SSC Lists of Validated Products and Solutions*?

☐ Yes ☒ No

Provide the following information regarding each item the entity uses from PCI SSC's Lists of Validated Products and Solutions:

Name of PCI SSC validated Product or Solution	Version of Product or Solution	PCI SSC Standard to which Product or Solution Was Validated	PCI SSC Listing Reference Number	Expiry Date of Listing
Not Applicable	Not Applicable	Not Applicable	Not Applicable	Not Applicable

* For purposes of this document, "Lists of Validated Products and Solutions" means the lists of validated products, solutions, and/or components, appearing on the PCI SSC website (www.pcisecuritystandards.org) (for example, 3DS Software Development Kits, Approved PTS Devices, Validated Payment Software, Point to Point Encryption (P2PE) solutions, Software-Based PIN Entry on COTS (SPoC) solutions, Contactless Payments on COTS (CPoC) solutions), and Mobile Payments on COTS (MPoC) products.

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Part 2. Executive Summary *(continued)*

Part 2f. Third-Party Service Providers
*(***ROC Section 4.4***)*

For the services being validated, does the entity have relationships with one or more third-party service providers that:

• Store, process, or transmit account data on the entity's behalf (for example, payment gateways, payment processors, payment service providers (PSPs, and off-site storage))	☐ Yes ☒ No
• Manage system components included in the entity's Assessment (for example, via network security control services, anti-malware services, security incident and event management (SIEM), contact and call centers, web-hosting companies, and IaaS, PaaS, SaaS, and FaaS cloud providers)	☒ Yes ☐ No
• Could impact the security of the entity's CDE (for example, vendors providing support via remote access, and/or bespoke software developers).	☒ Yes ☐ No

If Yes:

Name of Service Provider:	Description of Services Provided:
AWS	Cloud hosting provider
Azure	Cloud hosting provider
CoreSite	Colocation data center
Equinix	Colocation data center
QTS	Colocation data center
Sabey	Colocation data center

Note: *Requirement 12.8 applies to all entities in this list.*

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Part 2. Executive Summary *(continued)*

Part 2g. Summary of Assessment (ROC Section 1.8.1)

Indicate below all responses provided within each principal PCI DSS requirement.

For all requirements identified as either "Not Applicable" or "Not Tested," complete the "Justification for Approach" table below.

Note: *One table to be completed for each service covered by this AOC. Additional copies of this section are available on the PCI SSC website.*

Name of Service Assessed: GitHub Enterprise Cloud, Proxima (GitHub Enterprise Cloud with Data Residency), GitHub Copilot, GitHub Actions

PCI DSS Requirement	Requirement Finding More than one response may be selected for a given requirement. Indicate all responses that apply.				Select If a Compensating Control(s) Was Used
	In Place	Not Applicable	Not Tested	Not in Place	
Requirement 1:	☒	☒	☐	☐	☐
Requirement 2:	☒	☒	☐	☐	☐
Requirement 3:	☐	☒	☐	☐	☐
Requirement 4:	☐	☒	☐	☐	☐
Requirement 5:	☒	☒	☐	☐	☐
Requirement 6:	☒	☒	☐	☐	☐
Requirement 7:	☒	☒	☐	☐	☐
Requirement 8:	☒	☒	☐	☐	☐
Requirement 9:	☒	☒	☐	☐	☐
Requirement 10:	☒	☒	☐	☐	☐
Requirement 11:	☒	☒	☐	☐	☐
Requirement 12:	☒	☒	☐	☐	☐
Appendix A1:	☒	☐	☐	☐	☐
Appendix A2:	☐	☒	☐	☐	☐

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

Justification for Approach	
For any Not Applicable responses, identify which sub-requirements were not applicable and the reason.	1.2.6, 2.2.5 - There are no insecure services, protocols, or ports in use. 1.4.4, Requirement 3, Requirement 4, 6.5.5, 7.2.6, 10.2.1.1 - GitHub does not directly store, process, or transmit account data. 1.3.3, 2.3.1, 2.3.2 - GitHub does not have any wireless networks in-scope. 5.2.3, 5.2.3.1 - All in-scope system components have anti-malware software installed. 5.3.2.1 - The malware solution performs continuous behavioral analysis. 6.4.1 - This requirement has been superseded by Requirement 6.4.2. 6.4.3, 11.6.1 - There are no payment pages in scope. 6.5.2, 11.3.1.3, 11.3.2.1 - No significant changes to the in-scope environment have occurred in the past 12 months. 8.2.2 - GitHub does not utilize shared, group or generic identification, or other shared authentication credentials to access systems or platforms. 8.2.3 - GitHub does not have remote access to any customer premises within the in-scope environment. 8.2.7 - Third-party entities do not have accounts used for accessing, supporting or maintaining system components via remote access. 8.3.9 - Passwords/passphrases are not permitted to be the only authentication factor for user access. 8.3.10 - This control has been superseded by Requirement 8.3.10.1. 8.3.10.1 - Customers retain responsibility for rotating passwords or implementing dynamic monitoring of accounts. 8.6.1, 8.6.2, 8.6.3 – There are no systems or applications that use interactive login. 9.4.1, 9.4.1.1, 9.4.1.2, 9.4.2, 9.4.3, 9.4.4, 9.4.5, 9.4.5.1, 9.4.6, 9.4.7 - GitHub does not generate any media with cardholder data in any form (digital or non-digital media). 9.5.1, 9.5.1.1, 9.5.1.2, 9.5.1.2.1, 9.5.1.3, A2.1.1, A2.1.2, A2.1.3 - GitHub does not own/maintain any POS/POI devices. 10.4.2, 10.4.2.1 – All logs are monitored in accordance with Requirement 10.4.1. 10.7.1 - This control has been superseded by Requirement 10.7.2. 11.4.4 – No exploitable vulnerabilities were found during the penetration test. 11.4.5, 11.4.6 - Segmentation is not used within the GitHub environment. 12.3.2 - GitHub does not use a customized approach to meet any PCI DSS requirements. 12.5.3 - No significant organizational structure changes have occurred in the past 12 months.
For any Not Tested responses, identify which sub-requirements were not tested and the reason.	Not Applicable

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

Section 2 Report on Compliance

(**ROC Sections 1.2 and 1.3**)

Date Assessment began: ***Note:*** *This is the first date that evidence was gathered, or observations were made.*	8/6/2025
Date Assessment ended: ***Note:*** *This is the last date that evidence was gathered, or observations were made.*	12/29/2025
Were any requirements in the ROC unable to be met due to a legal constraint?	☐ Yes ☒ No
Were any testing activities performed remotely?	☒ Yes ☐ No

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

Section 3 Validation and Attestation Details

Part 3. PCI DSS Validation (ROC Section 1.7)

This AOC is based on results noted in the ROC dated *1/6/2026*.

Indicate below whether a full or partial PCI DSS assessment was completed:

☒ **Full Assessment** – All requirements have been assessed and therefore no requirements were marked as Not Tested in the ROC.

☐ **Partial Assessment** – One or more requirements have not been assessed and were therefore marked as Not Tested in the ROC. Any requirement not assessed is noted as Not Tested in Part 2g above.

Based on the results documented in the ROC noted above, each signatory identified in any of Parts 3b-3d, as applicable, assert(s) the following compliance status for the entity identified in Part 2 of this document *(select one)*:

☒	**Compliant:** All sections of the PCI DSS ROC are complete, and all assessed requirements are marked as being either In Place or Not Applicable, resulting in an overall **COMPLIANT** rating; thereby *GitHub* has demonstrated compliance with all PCI DSS requirements except those noted as Not Tested above.
☐	**Non-Compliant:** Not all sections of the PCI DSS ROC are complete, or one or more requirements are marked as Not in Place, resulting in an overall **NON-COMPLIANT** rating; thereby *Not Applicable* has not demonstrated compliance with PCI DSS requirements. **Target Date** for Compliance: *Not Applicable* An entity submitting this form with a Non-Compliant status may be required to complete the Action Plan in Part 4 of this document. Confirm with the entity to which this AOC will be submitted before completing Part 4.
☐	**Compliant but with Legal exception:** One or more assessed requirements in the ROC are marked as Not in Place due to a legal restriction that prevents the requirement from being met and all other assessed requirements are marked as being either In Place or Not Applicable, resulting in an overall **COMPLIANT BUT WITH LEGAL EXCEPTION** rating; thereby *Not Applicable* has demonstrated compliance with all PCI DSS requirements except those noted as Not Tested above or as Not in Place due to a legal restriction. This option requires additional review from the entity to which this AOC will be submitted. *If selected, complete the following:*

Affected Requirement	Details of how legal constraint prevents requirement from being met
Not Applicable	Not Applicable

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Part 3. PCI DSS Validation *(continued)*

Part 3a. Service Provider Acknowledgement

Signatory(s) confirms:
(Select all that apply)

☒	The ROC was completed according to *PCI DSS*, Version 4.0.1 and was completed according to the instructions therein.
☒	All information within the above-referenced ROC and in this attestation fairly represents the results of the Assessment in all material respects.
☒	PCI DSS controls will be maintained at all times, as applicable to the entity's environment.

Part 3b. Service Provider Attestation

Signed by:
Alexis Wales
3D55FA65CE89492...

Signature of Service Provider Executive Officer ↑	Date: 1/6/2026
Service Provider Executive Officer Name: Alexis Wales	Title: Chief Information Security Officer

Part 3c. Qualified Security Assessor (QSA) Acknowledgement

If a QSA was involved or assisted with this Assessment, indicate the role performed:	☒ QSA performed testing procedures.
	☐ QSA provided other assistance. If selected, describe all role(s) performed: Not Applicable

Signed by:
Blake Yanez
0F849974F9514F8...

Signature of Lead QSA ↑	Date: 1/6/2026
Lead QSA Name: Blake Yanez	

DocuSigned by:
Samuel Bizimungu
CEF93C177332471...

Signature of Duly Authorized Officer of QSA Company ↑	Date: 1/6/2026
Duly Authorized Officer Name: Samuel Bizimungu	QSA Company: Coalfire Systems, Inc.

Part 3d. PCI SSC Internal Security Assessor (ISA) Involvement

If an ISA(s) was involved or assisted with this Assessment, indicate the role performed:	☐ ISA(s) performed testing procedures.
	☐ ISA(s) provided other assistance. If selected, describe all role(s) performed: Not Applicable

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.

Docusign Envelope ID: 4F74D7A9-CF0D-463D-817C-0160C5484C3C

Part 4. Action Plan for Non-Compliant Requirements

Only complete Part 4 upon request of the entity to which this AOC will be submitted, and only if the Assessment has Non-Compliant results noted in Section 3.

If asked to complete this section, select the appropriate response for "Compliant to PCI DSS Requirements" for each requirement below. For any "No" responses, include the date the entity expects to be compliant with the requirement and provide a brief description of the actions being taken to meet the requirement.

PCI DSS Requirement	Description of Requirement	Compliant to PCI DSS Requirements (Select One)		Remediation Date and Actions (If "NO" selected for any Requirement)
		YES	NO	
1	Install and maintain network security controls	☐	☐	
2	Apply secure configurations to all system components	☐	☐	
3	Protect stored account data	☐	☐	
4	Protect cardholder data with strong cryptography during transmission over open, public networks	☐	☐	
5	Protect all systems and networks from malicious software	☐	☐	
6	Develop and maintain secure systems and software	☐	☐	
7	Restrict access to system components and cardholder data by business need to know	☐	☐	
8	Identify users and authenticate access to system components	☐	☐	
9	Restrict physical access to cardholder data	☐	☐	
10	Log and monitor all access to system components and cardholder data	☐	☐	
11	Test security systems and networks regularly	☐	☐	
12	Support information security with organizational policies and programs	☐	☐	
Appendix A1	Additional PCI DSS Requirements for Multi-Tenant Service Providers	☐	☐	
Appendix A2	Additional PCI DSS Requirements for Entities using SSL/early TLS for Card-Present POS POI Terminal Connections	☐	☐	

Note: The PCI Security Standards Council is a global standards body that provides resources for payment security professionals developed collaboratively with our stakeholder community. Our materials are accepted in numerous compliance programs worldwide. Please check with your individual compliance accepting organization to ensure that this form is acceptable in their program. For more information about PCI SSC and our stakeholder community please visit: https://www.pcisecuritystandards.org/about_us/

© 2006–2024 PCI Security Standards Council, LLC. All rights reserved.